[Año]

Fundamentos de ciberseguridad

TEMA 1 EJERCICIO 1.1

YOLANDA RODRÍGUEZ MORENO

ÍNDICE:

Tabla de contenido

TEMA 1: FUNDAMENTOS DE CIBERSEGURIDAD 2

EJERCICIO 1.1 GLOSARIO 2

1.Amenazas y vulnerabilidades informáticas. 2

2.Medidas de protección básicas. 4

3. Análisis de los incidentes de seguridad. 5

4. Herramientas y tecnologías de aplicación. 6

Entre las herramientas más habituales encontramos las siguientes: 7

Cortafuegos: controla las conexiones que entran y salen de un equipo o una red y permite bloquear aquellas que no cumplen las reglas establecidas. 7

IDS (Intrusion Detection System): sistema que analiza la actividad y detecta posibles intrusiones o comportamientos sospechosos. Su función principal es avisar. 7

IPS (Intrusion Prevention System): además de detectar actividades sospechosas, puede actuar para bloquearlas o impedir que continúen. 7

Antivirus: programa destinado principalmente a detectar, bloquear y eliminar virus y otros programas maliciosos. 7

Antimalware: tiene una función más amplia y busca detectar diferentes tipos de malware, como troyanos, spyware, ransomware o virus. 7

Tipos de cortafuegos 7

Cortafuegos basado en red: controla el tráfico que circula entre diferentes redes y puede proteger varios dispositivos al mismo tiempo. 7

Cortafuegos basado en host: está instalado directamente en un equipo y controla las conexiones de ese dispositivo concreto. 7

Los cortafuegos, IDS e IPS forman parte de las herramientas de protección contempladas en las guías de seguridad del Centro Criptológico Nacional. 7

Fuentes 7

CCN – Guías de Seguridad CCN-STIC 7

INCIBE – Instituto Nacional de Ciberseguridad 7

5. Normativa y buenas prácticas de uso. 7

6.Charla-Auditoria de ciberseguridad 9

TEMA 1: FUNDAMENTOS DE CIBERSEGURIDAD

EJERCICIO 1.1 GLOSARIO

1.Amenazas y vulnerabilidades informáticas.

Una amenaza es algo que puede provocar un daño en un sistema informático, mientras que una vulnerabilidad es una debilidad que puede ser aprovechada para conseguirlo.

INCIBE – Amenaza vs. vulnerabilidad: cómo diferenciarlos

En seguridad informática estos dos conceptos están muy relacionados, pero no significan lo mismo. Una amenaza representa un posible peligro, mientras que una vulnerabilidad es el punto débil que puede facilitar que ese peligro llegue a producirse.Las amenazas pueden ser **activas**, cuando intentan modificar, destruir o alterar información o sistemas, o **pasivas**, cuando buscan obtener información sin modificar directamente el sistema.

También podemos valorar las consecuencias de un ataque teniendo en cuenta tres principios básicos:

- **Confidencialidad:** la información solo debe estar disponible para las personas autorizadas.
- **Integridad:** los datos deben mantenerse correctos y no modificarse sin permiso.
- **Disponibilidad:** los sistemas y la información deben poder utilizarse cuando sean necesarios.

Estos tres principios forman una base importante de la seguridad de la información.

Principales conceptos

Amenaza: situación, acción o elemento que puede causar daños en un sistema, en sus datos o en sus usuarios.

Vulnerabilidad: debilidad o fallo de un sistema que puede ser aprovechado para comprometer su seguridad.

Confidencialidad: intenta evitar que personas no autorizadas puedan acceder a una información.

Integridad: busca que la información no sea modificada, eliminada o alterada sin autorización.

Disponibilidad: garantiza que los sistemas y los datos puedan utilizarse cuando los usuarios autorizados los necesiten.

Malware: software creado para realizar acciones perjudiciales o no autorizadas. Dentro de este grupo encontramos virus, troyanos, gusanos, spyware y ransomware, entre otros.

Ingeniería social: utiliza el engaño o la manipulación de las personas para conseguir información, acceso o alguna acción que beneficie al atacante. Muchas veces el objetivo no es atacar directamente al sistema, sino conseguir que la propia persona facilite la entrada.

DoS: ataque que intenta dejar un servicio o sistema sin funcionar mediante una gran cantidad de peticiones o utilizando sus recursos hasta saturarlos.

DDoS: es parecido al DoS, pero las peticiones proceden de muchos dispositivos al mismo tiempo, lo que hace que el ataque sea más difícil de controlar.

Man-in-the-middle (MITM): ataque en el que una persona consigue colocarse entre dos partes que se están comunicando para interceptar o incluso modificar la información que intercambian.

Exploit: código, programa o técnica que aprovecha una vulnerabilidad concreta para realizar una acción que normalmente no debería ser posible.

Inyección SQL: ataque que aprovecha una aplicación que no controla correctamente los datos introducidos por el usuario para manipular consultas SQL y acceder, modificar o eliminar información de una base de datos. INCIBE sigue registrando vulnerabilidades de este tipo en aplicaciones actuales.

Cross-Site Scripting (XSS): vulnerabilidad que permite introducir código, normalmente JavaScript, en una página web para que pueda ejecutarse en el navegador de otros usuarios.

Cifrar: transformar la información para que no pueda ser entendida por cualquiera que acceda a ella. Para recuperar la información original es necesario descifrarla mediante el procedimiento o clave correspondiente.

Ransomware: tipo de malware que bloquea el acceso a un equipo o cifra sus archivos y después pide un rescate para intentar recuperar el acceso.

Fuentes

INCIBE – Glosario de ciberseguridad

INCIBE – Medidas de prevención contra ataques DoS y DDoS

INCIBE – Guía sobre ransomware

.

2.Medidas de protección básicas.

Las medidas de protección son mecanismos que ayudan a controlar quién puede acceder a un sistema, qué puede hacer y qué comunicaciones están permitidas.

Para proteger un sistema no basta con instalar un antivirus. Hay que controlar los accesos, revisar el tráfico de red, observar lo que ocurre y comprobar periódicamente si existen problemas de seguridad.

Algunas medidas básicas son las siguientes:

Autenticación multifactor (MFA): método que utiliza dos o más formas diferentes para comprobar que una persona es realmente quien dice ser. Por ejemplo, una contraseña y un código recibido en el móvil.

Rol: función que tiene un usuario dentro de un sistema y que determina qué acciones puede realizar.

Permiso: autorización concreta que indica qué puede hacer un usuario o un rol, como leer, modificar, crear o eliminar información.

Reglas: condiciones que indican qué acciones están permitidas y cuáles deben bloquearse.

Filtrado: revisión del tráfico o de la información para dejar pasar lo permitido y bloquear aquello que no cumple las reglas.

Puerto: número que permite identificar un servicio o aplicación concreta dentro de una conexión de red. Ayuda a dirigir los datos hacia el programa correspondiente.

Protocolo: conjunto de reglas que permite que diferentes dispositivos se comuniquen siguiendo una forma determinada.

Router: dispositivo que dirige los datos entre diferentes redes para que lleguen al destino correspondiente.

Monitorear: observar de forma continua un sistema o una red para detectar comportamientos extraños, fallos o posibles amenazas.

Auditoría: revisión de un sistema y de sus medidas de seguridad para detectar problemas, vulnerabilidades y posibles mejoras.

El control de accesos y la gestión de riesgos son también elementos importantes dentro de la seguridad de los sistemas. El ENS, por ejemplo, incluye expresamente la autorización y control de los accesos y el principio de mínimo privilegio.

Fuentes

INCIBE – Instituto Nacional de Ciberseguridad

CCN – Centro Criptológico Nacional, guías de seguridad

3. Análisis de los incidentes de seguridad.

Un **incidente de seguridad** es un suceso que afecta o puede afectar a la seguridad de un sistema, una red o la información que contiene. Para solucionarlo se sigue un proceso que permite detectarlo, analizarlo, contenerlo, eliminar la causa y recuperar el funcionamiento normal.

Cuando ocurre un incidente no se trata simplemente de solucionar el problema y seguir trabajando. Primero hay que saber qué ha pasado, hasta dónde ha llegado y qué elementos pueden haberse visto afectados.

El ciclo de actuación puede dividirse en varias fases:

Detección: se identifica que puede estar ocurriendo un problema de seguridad.

Análisis: se estudia lo sucedido para averiguar cómo comenzó, qué sistemas están afectados y qué consecuencias puede tener.

Contención: se intenta limitar el incidente para evitar que continúe extendiéndose o causando daños.

Erradicación: se elimina la causa del problema, por ejemplo un malware o la vulnerabilidad que permitió el ataque.

Recuperación: se vuelven a poner en funcionamiento los sistemas afectados de manera segura y se comprueba que todo funciona correctamente.

Aprendizaje: después del incidente se revisa lo ocurrido para detectar errores y mejorar las medidas de seguridad. Esta parte es importante porque permite evitar que el mismo problema vuelva a repetirse.

Otros conceptos

Indicadores de compromiso (IoC): señales o datos que pueden indicar que un sistema ha sido comprometido. Pueden ser, por ejemplo, archivos sospechosos, procesos extraños, modificaciones en registros o direcciones relacionadas con una actividad maliciosa.

Estrategia proactiva: forma de trabajar que intenta detectar riesgos antes de que se produzca un incidente, en lugar de esperar a que el problema aparezca.

Análisis forense: proceso mediante el cual se recogen, conservan y estudian evidencias digitales para averiguar qué ocurrió y cómo se produjo un incidente.

El ENS también contempla la prevención, detección y respuesta ante incidentes como parte del proceso de seguridad.

Fuentes

INCIBE – Guía nacional de notificación y gestión de ciberincidentes

CCN – Indicadores de compromiso y análisis de intrusiones

BOE – Esquema Nacional de Seguridad

Detección → Análisis → Contención → Erradicación → Recuperación → Aprendizaje

4. Herramientas y tecnologías de aplicación.

Las herramientas de seguridad sirven para controlar las comunicaciones, detectar actividades sospechosas y evitar que programas maliciosos o accesos no autorizados puedan comprometer un sistema.

Entre las herramientas más habituales encontramos las siguientes:

Cortafuegos: controla las conexiones que entran y salen de un equipo o una red y permite bloquear aquellas que no cumplen las reglas establecidas.

IDS (Intrusion Detection System): sistema que analiza la actividad y detecta posibles intrusiones o comportamientos sospechosos. Su función principal es avisar.

IPS (Intrusion Prevention System): además de detectar actividades sospechosas, puede actuar para bloquearlas o impedir que continúen.

Antivirus: programa destinado principalmente a detectar, bloquear y eliminar virus y otros programas maliciosos.

Antimalware: tiene una función más amplia y busca detectar diferentes tipos de malware, como troyanos, spyware, ransomware o virus.

Tipos de cortafuegos

Cortafuegos basado en red: controla el tráfico que circula entre diferentes redes y puede proteger varios dispositivos al mismo tiempo.

Cortafuegos basado en host: está instalado directamente en un equipo y controla las conexiones de ese dispositivo concreto.

Los cortafuegos, IDS e IPS forman parte de las herramientas de protección contempladas en las guías de seguridad del Centro Criptológico Nacional.

Fuentes

CCN – Guías de Seguridad CCN-STIC

INCIBE – Instituto Nacional de Ciberseguridad

5. Normativa y buenas prácticas de uso.

Las normas de seguridad establecen cómo se deben proteger los sistemas y los datos. Entre las más importantes en este ámbito encontramos el **RGPD, la ISO/IEC 27001 y el ENS**.

La seguridad informática también tiene una parte relacionada con las normas y la forma correcta de tratar la información. No todo consiste en instalar programas de protección. También hay que saber qué datos se pueden utilizar, quién puede acceder a ellos y cómo deben protegerse.

Reglamento General de Protección de Datos (RGPD): normativa europea que establece cómo deben tratarse los datos personales y qué derechos tienen las personas sobre ellos. También obliga a aplicar medidas de seguridad adecuadas al riesgo que pueda existir para esos datos.

ISO/IEC 27001: norma internacional que establece los requisitos para crear, mantener y mejorar un sistema de gestión de la seguridad de la información. Su objetivo es ayudar a las organizaciones a gestionar los riesgos relacionados con la información.

Esquema Nacional de Seguridad (ENS): marco establecido en España para proteger la información y los servicios utilizados por las administraciones públicas. El ENS se basa, entre otros principios, en la prevención, detección y respuesta, la gestión de riesgos y la vigilancia continua.

Otros conceptos

Datos sensibles: son datos personales que necesitan una protección especial por el impacto que puede tener su tratamiento sobre los derechos y libertades de una persona. El RGPD incluye, entre otros, datos relativos a la salud, datos genéticos y biométricos, origen étnico o racial, opiniones políticas, religión, vida sexual u orientación sexual y afiliación sindical.

Políticas de acceso: normas que determinan quién puede acceder a un sistema, a qué información puede entrar y qué acciones tiene permitidas.

Ciclo de vida de la información: conjunto de etapas por las que pasa la información desde que se crea o se obtiene hasta que se almacena, utiliza, comparte y finalmente se elimina.

Diagnóstico de fallos: proceso de buscar el origen de un problema o error para poder solucionarlo correctamente.

Propuestas de mejora: cambios o medidas que se plantean para corregir problemas y aumentar la seguridad o el funcionamiento de un sistema.

Registro de incidencias: documento o sistema donde se anotan los incidentes que ocurren, junto con información sobre lo sucedido y las actuaciones realizadas.

Fuentes

AEPD – Conceptos básicos de protección de datos

AEPD – Seguridad de los tratamientos

ISO – ISO/IEC 27001

BOE – Real Decreto 311/2022, Esquema Nacional de Seguridad

6.Charla-Auditoria de ciberseguridad

1. ¿Qué es la ciberseguridad?

La ciberseguridad consiste en proteger los sistemas informáticos, las redes, las aplicaciones y los datos de una empresa frente a posibles ataques. Se busca evitar accesos sin permiso, robos de información y problemas que puedan afectar al funcionamiento de los servicios.

Una parte importante es encontrar los fallos antes de que alguien los aproveche. Para ello se realizan análisis de seguridad y pruebas controladas.

Hay que distinguir varios conceptos:

- Ciberseguridad: protección frente a amenazas digitales.
- Seguridad informática: protección de los equipos, programas y redes.
- Seguridad de la información: protección de la información, tanto digital como física, por ejemplo, los documentos en papel.

Están muy relacionadas, pero no son exactamente lo mismo.

2. Ransomware y phishing

El ransomware es un tipo de malware que cifra o bloquea los archivos de una víctima para exigir un rescate. Puede llegar a paralizar una empresa si afecta a sus servidores o bases de datos.

Una web relacionada con este tema es Ransomware.live, que permite seguir la actividad de grupos de ransomware y consultar información sobre ataques y organizaciones afectadas. Sirve para conocer amenazas recientes y observar cómo actúan estos grupos.

El phishing funciona de otra manera. Consiste en engañar a una persona para conseguir sus contraseñas, datos bancarios u otra información. Lo más habitual es recibir un correo que parece legítimo y que lleva a una página falsa.

Si se detecta un phishing, hay que evitar abrir sus enlaces, comunicarlo al responsable de seguridad y, si procede, bloquear o retirar la página fraudulenta mediante los canales correspondientes. También se puede informar a INCIBE.

3. Análisis de vulnerabilidades

Una vulnerabilidad es un fallo o una debilidad que puede comprometer la seguridad de un sistema. Puede deberse a un programa desactualizado, una contraseña débil o una configuración incorrecta.

El análisis de vulnerabilidades busca estos problemas para que puedan corregirse antes de que alguien los aproveche.

No es lo mismo que un pentesting. En una prueba de penetración se intenta comprobar, de forma controlada y con autorización, si determinados fallos pueden explotarse realmente y qué consecuencias tendrían.

Una auditoría de seguridad es más amplia. Puede revisar los sistemas, los permisos, las configuraciones y los procedimientos de una empresa.

4. Información que la empresa entrega a la empresa de ciberseguridad

Antes de empezar el trabajo, la empresa que contrata el servicio debe indicar qué activos quiere analizar y facilitar los contactos responsables. Así se delimita el trabajo y se sabe a quién avisar si se encuentra un problema.

4.1. Activos

Los activos son los recursos de la empresa que tienen valor y que deben protegerse.

- **Direcciones IP:** identifican equipos o interfaces de red. Las IP públicas pueden corresponder a servidores accesibles desde Internet; las privadas se utilizan normalmente dentro de las redes internas.
- **URL:** dirección que permite acceder a un recurso concreto de una web. Por ejemplo, https://empresa.es/clientes.
- **Nombres de dominio:** nombres que se utilizan para acceder a páginas y servicios, como empresa.es. También se incluyen los subdominios, por ejemplo, correo.empresa.es**.**
- **Otros activos:** servidores, aplicaciones web, APIs, servicios en la nube y equipos de red.

La empresa de ciberseguridad utiliza esta información para saber qué tiene que revisar. Es importante identificar correctamente los sistemas propios y los de terceros, porque no se pueden analizar recursos ajenos sin la autorización correspondiente.

4.2. Contactos: grupos 1, 2 y 3

También se facilitan los datos de las personas con las que se debe contactar durante el análisis. En tus apuntes aparecen tres grupos.

Una posible organización sería la siguiente, aunque hay que confirmar la función exacta de cada grupo con la empresa que dio la charla:

- **Grupo 1:** contacto técnico, como el administrador de sistemas. Puede revisar los equipos y aplicar correcciones.

- **Grupo 2:** responsable de informática o seguridad, que coordina las actuaciones y valora la gravedad de los problemas.
- **Grupo 3:** responsable con mayor capacidad de decisión, como alguien de dirección, al que se avisa cuando la situación requiere decisiones importantes.

Por ejemplo, si se encuentra una vulnerabilidad grave en un servidor, se debe comunicar al contacto correspondiente y escalar la incidencia si es necesario.

La finalidad es que los problemas se comuniquen rápidamente y que cada persona sepa qué tiene que hacer.

5. Tipos de análisis de seguridad

En la charla se mencionaron distintos tipos de análisis. Cada uno se centra en una parte de la seguridad.

Análisis de puertos abiertos

Los puertos permiten que los equipos se comuniquen mediante diferentes servicios. Con este análisis se comprueba cuáles están abiertos y qué servicios responden.

Por ejemplo, un servidor web puede utilizar los puertos 80 y 443. Si aparece un servicio que no debería estar accesible, habría que revisar su configuración.

Análisis de vulnerabilidades

Busca fallos conocidos en programas, servidores y aplicaciones. Puede detectar versiones antiguas o configuraciones inseguras.

Los resultados ayudan a decidir qué problemas hay que solucionar primero. No todos tienen la misma gravedad.

Análisis de seguridad de servicios web

Consiste en revisar la seguridad de las páginas web y sus aplicaciones. Se comprueban los accesos, los permisos, los formularios y la gestión de las sesiones, entre otras cosas.

Por ejemplo, una web podría permitir que un usuario accediera a información privada de otra cuenta. Es un fallo que podría poner en peligro los datos de los clientes.

Análisis de certificados y configuración SSL/TLS

Se comprueba si los certificados digitales son válidos y si la conexión HTTPS está bien configurada.

TLS protege las comunicaciones entre el navegador y el servidor. **SSL** es su antecesor y está obsoleto.

Una herramienta para comprobar la configuración de servidores web es

SSL Labs.

Análisis de correo electrónico: SPF, DKIM y DMARC

Estos mecanismos ayudan a evitar que alguien suplante el dominio de correo de una empresa**.**

- **SPF:** indica qué servidores están autorizados para enviar correo en nombre de un dominio.
- **DKIM:** permite comprobar una firma digital asociada al mensaje
- **DMARC:** establece qué hacer con los mensajes que no superan las comprobaciones y permite recibir informes.

Se utilizan para mejorar la protección del correo corporativo y reducir la suplantación de identidad.

Análisis de exposición digital

Consiste en averiguar qué información y servicios de una empresa se pueden encontrar desde Internet. Se revisan dominios, subdominios, direcciones IP, servidores y otros recursos públicos.

A veces quedan servicios antiguos accesibles que ya no se utilizan. Si no están actualizados o protegidos, pueden convertirse en un riesgo.

Auditoría de configuración

Se revisan los permisos, las cuentas, las actualizaciones, las contraseñas y las reglas del cortafuegos, entre otros elementos.

Un sistema puede no tener vulnerabilidades conocidas y, aun así, estar mal configurado.

Pentesting o prueba de penetración

Se intenta comprobar si determinados fallos se pueden aprovechar en la práctica. Se hace bajo unas condiciones acordadas y con autorización.

El objetivo es conocer el impacto que tendría un ataque y proponer medidas para evitarlo.

Análisis de ingeniería social

Se centra en los engaños que utilizan los atacantes para manipular a las personas. Por ejemplo, se pueden realizar campañas de phishing autorizadas para comprobar si los trabajadores reconocen los correos sospechosos.

También se puede revisar la seguridad física, como el acceso a las salas de servidores y la protección de los equipos.

6. Herramientas y páginas web de los apuntes

Shodan

Shodan es un buscador de dispositivos y servicios conectados a Internet. Permite consultar información sobre servidores, routers, cámaras y otros dispositivos que exponen servicios públicos.

Se utiliza para conocer qué recursos son visibles desde fuera y detectar posibles exposiciones.

Nmap

Nmap es una herramienta que permite descubrir equipos, analizar puertos abiertos e identificar servicios y versiones.

Se utiliza para conocer qué está funcionando en una red y localizar servicios que necesitan revisión.

NSE significa Nmap Scripting Engine. Es una función de Nmap que permite ejecutar scripts para realizar comprobaciones adicionales. Algunos obtienen información de los servicios y otros buscan posibles vulnerabilidades.

Hack The Box

Hack The Box es una plataforma para aprender ciberseguridad mediante ejercicios prácticos y laboratorios. Permite practicar análisis de sistemas y pruebas de penetración en entornos preparados para ello.

BitSight: Findings Table (tabla de hallazgos)

BitSight es una plataforma que permite evaluar la seguridad de una empresa a partir de información sobre sus sistemas y su exposición a Internet. Entre sus funciones está la Findings Table, que en español significa «tabla de hallazgos». Esta tabla reúne los problemas de seguridad detectados en los activos de una organización, como direcciones IP, dominios, servidores o aplicaciones. Por ejemplo, puede mostrar un puerto abierto, una configuración insegura, un certificado TLS/SSL con problemas o un sistema que utiliza software desactualizado.

Cada hallazgo incluye información para entender qué se ha detectado, a qué activo afecta, cuándo se observó y qué gravedad tiene. También puede incluir evidencias y recomendaciones para corregirlo.

¿Para qué se utiliza? Para tener los problemas identificados en un mismo lugar, valorar cuáles son más importantes y organizar su solución. Así, la empresa puede centrarse

primero en los fallos que suponen un mayor riesgo, en lugar de intentar corregirlos todos a la vez.

Puedes consultar la documentación oficial de BitSight

Findings Table: Finding Details Sheet.

MITRE ATT&CK

MITRE ATT&CK es una base de conocimiento que recoge tácticas y técnicas utilizadas por los atacantes.

Sirve para estudiar cómo actúan, qué intentan conseguir y cómo se pueden detectar sus acciones. Por ejemplo, permite relacionar una actividad sospechosa con técnicas conocidas y buscar medidas para prevenirla o detectarla.

TIRESIAS de INCIBE

TIRESIAS es un servicio de informes de ciberseguridad de INCIBE, relacionado con la información sobre la exposición digital de las organizaciones.

INCIBE es el Instituto Nacional de Ciberseguridad de España. Ofrece servicios y recursos para mejorar la seguridad digital.

TIRESIAS permite obtener información e informes sobre la exposición de una organización a Internet. Puede ayudar a conocer qué activos se encuentran expuestos y qué aspectos conviene revisar. No es lo mismo que una herramienta de pentesting: un informe de exposición ayuda a identificar riesgos, pero no implica necesariamente que se haya intentado explotar las vulnerabilidades.

CONAN**

Checkthe mark Python*

8. Cómo se realiza un análisis de seguridad

Primero se recopila la información de la empresa: activos, dominios, direcciones IP, servicios incluidos y contactos responsables.

Después se realiza el reconocimiento para identificar qué servicios están expuestos y se aplican las pruebas necesarias. Cuando aparecen posibles vulnerabilidades, hay que revisarlas para comprobar si son reales y valorar su gravedad.

Por último, se prepara un informe con los resultados y las medidas recomendadas. La empresa corrige los fallos y, si está previsto, se repite el análisis para comprobar que se han solucionado.

La idea es anticiparse a los problemas, no esperar a que se produzca un ataque.

9. Diferencia entre detectar, validar y corregir

- **Detectar: encontrar un posible fallo de seguridad.**
- **Validar: comprobar que el fallo existe realmente y valorar su impacto.**
- **Corregir: aplicar una solución, como actualizar un programa o modificar una configuración.**

Después se vuelve a comprobar el sistema. Así se verifica si la solución ha funcionado.

10. Resumen

La ciberseguridad busca proteger los sistemas y la información de una empresa. Para hacerlo, primero hay que conocer los activos que tiene y definir qué se puede analizar.

Después se revisan los puertos, las aplicaciones, las configuraciones y los posibles fallos. Herramientas como Nmap y Shodan ayudan a descubrir servicios expuestos, mientras que MITRE ATT&CK permite estudiar las técnicas que utilizan los atacantes. También existen plataformas de formación como Hack The Box y servicios de información sobre exposición digital, como TIRESIAS de INCIBE.

Por último, los resultados se comunican a los contactos responsables para que los problemas se corrijan. Encontrar una vulnerabilidad es importante, pero lo fundamental es entender el riesgo y solucionarlo antes de que alguien lo aproveche.

Fuentes para ampliar la información

- **INCIBE**
- **Nmap**
- **Shodan**
- **MITRE ATT&CK**
- **Hack The Box**
- **BitSight**
- **SSL Labs**
- **pyemailprotectionslib**